

# CCSP D6 法律風險與合規

CCSP flashcards for Knowt. 28 cards. Upload this PDF to AI PDF Summarizer.

**Q001 CMM 用來評估什麼？**

A 流程機制的嚴謹度、細節與可重複性 (repeatability)。看到這些詞不要選 CSA STAR。

**Q002 CSA STAR 用來做什麼？**

A 檢驗 / 展示雲端安全控制保證，不是量測流程成熟度。

**Q003 收到訴訟通知應立刻做什麼？**

A 啟動 Legal Hold，暫停常規 secure destruction / retention 銷毀，以保全證據。

**Q004 Legal hold 時要暫停威脅建模嗎？**

A 通常不是優先動作。優先是保全可能相關的資料與日誌。

**Q005 出庭前負責監管證物完整性的人是誰？**

A Evidence Custodian。不要選 Data Controller。

**Q006 Chain of custody 證明什麼？**

A 證物從收集到呈堂過程中的保管、移轉與完整性未被破壞。

**Q007 SOC 2 與 SOC 3 差在哪？**

A SOC 2 詳細且通常 restricted use；SOC 3 較高階、較常可公開。

**Q008 看到「公開摘要」與「詳細控制」分別偏向哪份 SOC？**

A 公開摘要偏 SOC 3；詳細控制與受限分發偏 SOC 2。

**Q009 ISO / IEC 是法律嗎？**

A 不是。它是制定國際標準的組織 / 標準體系。

**Q010 FedRAMP 是什麼？**

A 美國聯邦雲端安全授權計畫，針對雲端服務給政府使用的授權路徑。

**Q011 NIST SP 800-53 是什麼？**

A 安全與隱私控制目錄，不是稽核報告，也不是成熟度模型。

**Q012 HIPAA 主要保護什麼？**

A 美國健康資訊（PHI）的隱私與安全要求。不要和 GLBA（金融）或 PCI（支付卡）搞混。

**Q013 Common Criteria 是什麼？**

A IT 產品安全評估與保證等級框架（EAL 等），不是雲端營運稽核報告。

**Q014 Auditability 強調什麼？**

A 活動可被記錄、追蹤與獨立驗證。沒有 log / clock sync / custody 就很難審計。

**Q015 eDiscovery 與一般 backup 差在哪？**

A eDiscovery 是為訴訟 / 調查識別、保存、產出電子證據；backup 是復原營運資料。

**Q016 EU privacy adequacy 大致在問什麼？**

A 第三方國家是否被認定提供足夠個資保護，以支持跨境傳輸。

**Q017 GLBA 與 PCI DSS 再次對照？**

A GLBA = 美國聯邦金融隱私法；PCI DSS = 支付卡安全標準。

**Q018 DMCA / copyright 題不要選成什麼？**

A 不要選成隱私或資安控制框架。它處理著作權與數位內容保護。

**Q019 ISO 31000 與 NIST 800-37 各偏什麼？**

A ISO 31000 是風險管理原則；NIST 800-37 是 RMF（風險管理框架）流程。

**Q020 Right to Audit 通常出現在哪？**

A 合約 / SLA 條款，讓客戶或指定稽核人有權查核 CSP 控制。不是單靠公開行銷聲明。

**Q021 Privacy Level Agreement 常被考的是什麼？**

A 隱私相關義務，尤其通報 / reporting obligation，而不只是時間長短。

**Q022 合約 / SLA incentive 的作用？**

A 用獎懲驅動 CSP 達成可用性、安全或通報義務，而不只寫願望。

**Q023 資料跨境時最該先想到什麼？**

A Jurisdiction、當地法律與能否合法轉移 / 存取資料。

**Q024 Forensic reporting 最在意什麼？**

A 方法可辯護、證據完整、chain of custody 清楚。不是先追求最快修復。

**Q025 Evidence integrity 常見技術控制？**

A Hashing、寫保護、雙人保管、完整日誌。分類本身不能替代保管鏈。

**Q026 把工作交給 processor 後，controller 還要做什麼？**

A 選擇適當 processor、用合約約束、持續監督。歸責不因委外而消失。

**Q027 SOC 報告能不能當成「我已完全合規」？**

A 不能自動等同。要看 Type、期間、範圍與是否涵蓋你關心的控制。

**Q028 訴訟保全時 retention 政策怎麼辦？**

A 與本案可能相關的資料停止例行銷毀，即使原本到期。